

Marks & Spencer Ransomware Attack



กิตติยพล ราศรี

6822011662007

กานท์ ยอดเกวียน

6811011662005

อนุกุล บุญทา

6811011662004

อชิป ธรรมปัญญา

Incident Overview

องค์กรที่ถูกโจมตี: Marks & Spencer (M&S)

บริษัทค้าปลีกชั้นนำของสหราชอาณาจักร มีพนักงาน 64,000 คน ร้านค้ากว่า 1,400 สาขาทั่วโลก

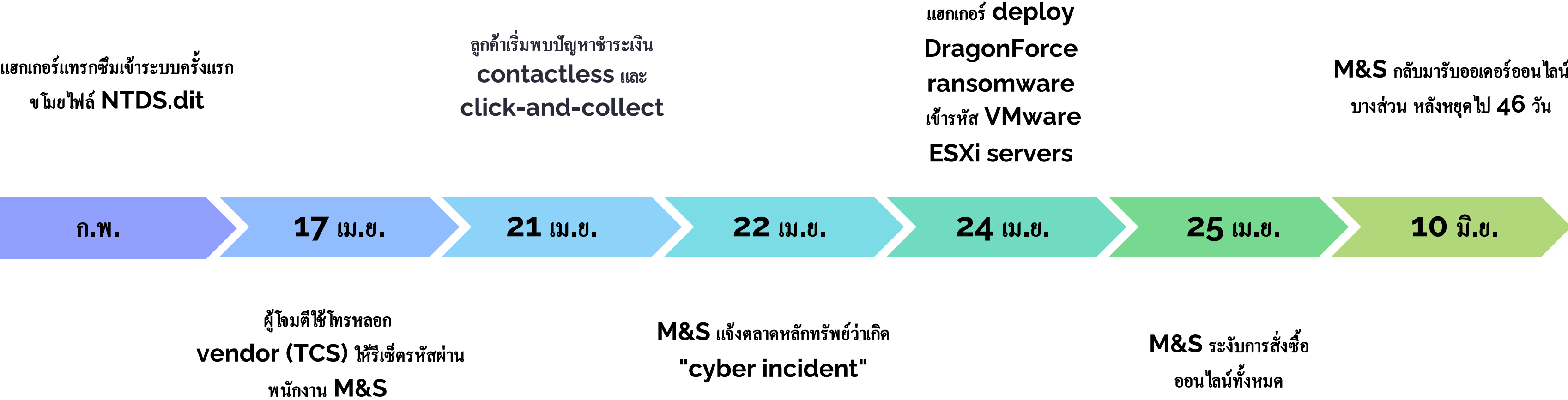
ประเภทการโจมตี: Ransomware Attack (DragonForce Ransomware)

กลุ่มผู้โจมตี: Scattered Spider — กลุ่มแฮกเกอร์วัยรุ่นที่พูดภาษาอังกฤษ จากสหราชอาณาจักรและสหรัฐอเมริกา

Asset: ระบบสั่งซื้อออนไลน์, ระบบชำระเงิน, เซิร์ฟเวอร์ VMware ESXi, ข้อมูลลูกค้า, ระบบ Active Directory



Attack Timeline



Threat

Analysis

C I A L ENGINEERING

- ผู้โจมตีปลอมตัวเป็นพนักงาน *M&S* โทรรหา *vendor* ภายนอก (*Tata Consultancy Services*) หลอกให้รีเซตรหัสผ่าน เป็นจุดเริ่มต้นของการโจมตีทั้งหมด

CREDENTIAL THEFT & LATERAL MOVEMENT

- ขโมยไฟล์ *NTDS.dit* เพื่อได้ *password hash* ของผู้ใช้ทั้งหมดใน *domain*
- เคลื่อนที่ภายในเครือข่าย (*lateral movement*) โดยใช้ *credential* ที่ถูกต้อง ทำให้ตรวจจับยาก

RANSOMWARE (DRAGONFORCE)

- เข้ารหัสเซิร์ฟเวอร์ทั้งหมดของ *M&S*
- ใช้กลยุทธ์ *Double Extortion* = เข้ารหัสข้อมูล + ขู่เผยแพร่ข้อมูลที่ขโมยมา

THIRD-PARTY / SUPPLY CHAIN RISK

- จุดอ่อนไม่ได้อยู่ที่ *M&S* โดยตรง แต่อยู่ที่ *vendor* ภายนอก
- แสดงให้เห็นความเสี่ยงของ *supply chain* ที่ขยายตัว

Impact

1 การเงิน

สูญเสียกำไรประมาณ £300 ล้าน
(~14,000 ล้านบาท),
สูญเสีย £40 ล้านต่อสัปดาห์

2 มูลค่าตลาด

หุ้นตก มูลค่าตลาดหายไปกว่า £750 ล้าน
(~35,000 ล้านบาท)

5 ชื่อเสียง

เป็นข่าวใหญ่ทั่วสหราชอาณาจักร กระทบความ
เชื่อมั่นผู้บริโภค

4 ข้อมูลลูกค้า

ชื่อ, อีเมล, วันเกิดลูกค้าร้อยละ (ข้อมูลการเงินไม่
ได้รับผลกระทบ)

3 การดำเนินงาน

ระบบออนไลน์หยุดทำงาน 46 วัน, พนักงานคลังสินค้า
~200 คน
ถูกสั่งให้หยุดงาน, ระบบ gift card ใช้ไม่ได้,
supplier ต้องกลับไปใช้กระดาษ



Security Controls

มาตรการที่ 1: ตัดการเชื่อมต่อ VPN และปิดระบบ

- สิ่งที่ทำ: M&S ตัด VPN ที่พนักงานใช้ทำงานระยะไกลทันที และปิดระบบที่ถูกโจมตีเพื่อหยุดการแพร่กระจาย
- **Respond** — ตอบสนองต่อเหตุการณ์เพื่อจำกัดความเสียหาย

มาตรการที่ 2: จ้างทีมผู้เชี่ยวชาญภายนอกสืบสวน

- สิ่งที่ทำ: จ้าง CrowdStrike, Microsoft และ Fenix24 มาสืบสวนและกู้คืนระบบ
- **Recover** — กู้คืนระบบให้กลับมาทำงานปกติ

Key

Takeaways

- คนคือจุดอ่อน: พนักงานต้องมีความตระหนักรู้ เพราะเป็นช่องทางโจมตีที่ง่ายที่สุด
- คุมความเสี่ยงคู่ค้า: ตรวจสอบระบบของ **Third-party** ที่เชื่อมต่อกับเรา
- ระวัง **Ransomware**: เตรียมรับมือมัลแวร์เรียกค่าไถ่ที่สร้างความเสียหายรุนแรง
- ต้องมีแผนรับมือ: มีขั้นตอนชัดเจนเมื่อเกิดเหตุ (**Incident Response**) เพื่อกู้คืนระบบให้ไว
- ใช้แนวคิด **Zero Trust**: ไม่ไว้วางใจใคร ตรวจสอบการเข้าถึงทุกครั้งอย่างเข้มงวด